

PO01 – Politica de Certificados de Firma Electronica Avanzada

ID Documento: GOYA-PO01-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Publico **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Revision legal	Asesor Juridico	Abogado especialista en firma electronica
Aprobacion	Gerente General	Representante legal PSC

1.2 Distribucion

Destinatario	Medio
Entidad Acreditadora (Subsecretaria de Economia)	Repositorio web publico
Suscriptores	Repositorio web publico
Partes confiantes	Repositorio web publico
Personal operativo CA/RA	Sistema documental interno

1.3 Documentos relacionados

ID	Documento	Relacion
PS03	Plan de Continuidad del Negocio	Respaldo de operaciones CA
PS05	Autoevaluacion de Cumplimiento	Auditorias periodicas
PS06	Plan de Gestion de Claves	Ciclo de vida de claves CA y suscriptor
ET01	Especificacion Tecnica de Certificados	Perfiles X.509 detallados
SF01	Solicitud de Certificado FEA	Formulario de registro
CP.md	Certificate Policy (RFC 3647 completo)	Politica general PKI en ingles
CPS	Certification Practice Statement	Practicas de certificacion

1.4 Definiciones y acronimos

Termino	Definicion
CA	Autoridad Certificadora (Certification Authority)
RA	Autoridad de Registro (Registration Authority)
PSC	Prestador de Servicios de Certificacion
FEA	Firma Electronica Avanzada
FES	Firma Electronica Simple
CRL	Lista de Certificados Revocados
OCSP	Protocolo de Estado de Certificado en Linea
RUT	Rol Unico Tributario
DID	Identificador Descentralizado
HSM	Modulo de Seguridad de Hardware
QC	Certificado Cualificado (Qualified Certificate)
TSA	Autoridad de Sellado de Tiempo
ML-DSA-65	Module Lattice Digital Signature Algorithm, nivel de seguridad 3 (FIPS 204)

2. Introduccion

2.1 Descripcion general

La presente Politica de Certificados (PO01) establece los requisitos que rigen la emision, gestion, uso, suspension, revocacion y renovacion de certificados X.509v3 de Firma Electronica Avanzada (FEA) emitidos por Goya Ledger SpA en su calidad de Prestador de Servicios de Certificacion (PSC) acreditado bajo la Ley 19.799 de la Republica de Chile.

Goya Ledger opera una Infraestructura de Clave Publica (PKI) basada en blockchain que soporta la emision de certificados con algoritmos post-cuanticos (ML-DSA-65, FIPS 204), garantizando resistencia criptografica a largo plazo frente a amenazas de computacion cuantica.

Esta politica se estructura conforme a RFC 3647 “Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework” y satisface los requisitos del sub-proceso PO01 de la Guia de Acreditacion EA-103 v2.1 de la Entidad Acreditadora.

2.2 Identificacion de la politica

Atributo	Valor
Nombre	Politica de Certificados de Firma Electronica Avanzada
OID de la politica	1.3.6.1.4.1.99999.2.1 (CP_OID)
OID del CPS	1.3.6.1.4.1.99999.2.2 (CPS_OID)
OID de la TSA	1.3.6.1.4.1.99999.1.1 (TSA_POLICY_OID)
OID de la politica de firma	1.3.6.1.4.1.99999.3.1 (SIGNATURE_POLICY_OID)
Arco OID raiz	1.3.6.1.4.1.99999 (GOYA_OID_ROOT)
Version	1.0.0
URL de publicacion	https://goya.cl/pki/cp

Los OIDs estan definidos como constantes en `src/pki_policy.rs` y son inyectados automaticamente en la extension `certificatePolicies` (OID 2.5.29.32) de cada certificado emitido.

2.3 Alcance

Esta politica aplica a todos los certificados FEA emitidos por la CA de Goya Ledger para personas naturales, conforme al perfil `NaturalPerson` (`CertProfileType::NaturalPerson`) con nivel de aseguramiento `High` (`AssuranceLevel::High`).

Quedan fuera de alcance:

- Certificados FES (Firma Electronica Simple) con nivel Low.
- Certificados de sello electronico para personas juridicas (LegalPerson).
- Certificados de autenticacion web QWAC (WebAuthentication).
- Certificados internos de nodo para comunicacion P2P/TLS.

2.4 Participantes de la PKI

2.4.1 Autoridad Certificadora (CA)

La PKI de Goya Ledger emplea una jerarquia de dos niveles implementada en `src/pki.rs`:

- **CA Raiz (offline):** Certificado auto-firmado con CN “Rust-BC Internal CA”. Clave generada en ceremonia formal, almacenada offline en HSM. Firma exclusivamente certificados de CA Intermedia. Validez: 10 anos.
- **CA Intermedia (operacional):** CN “Goya Ledger Intermediate CA”, firmada por la CA Raiz. Realiza toda la operacion: firma de certificados de suscriptor, CRLs y respuestas OCSP. Validez: 5 anos. Restriccion pathLen: 0.

2.4.2 Autoridad de Registro (RA)

La RA ejecuta la verificacion de identidad previa a la emision del certificado, implementada en `src/identity/ra.rs`. Opera bajo los requisitos del Articulo 15 de la Ley 19.799.

Funciones de la RA:

- Recepcion y procesamiento de solicitudes de identidad.
- Validacion del RUT chileno mediante algoritmo modulo 11 (`validate_rut()`).
- Verificacion del nombre legal contra documentos oficiales.
- Aprobacion o rechazo de solicitudes con registro auditable.
- Emision del certificado tras verificacion exitosa (`approve_and_issue_cert()`).

Los oficiales de RA se identifican por su DID (`did:goya:{pubkey_hex[..16]}`) y todas las decisiones se registran con DID del oficial, marca de tiempo y disposicion.

2.4.3 Suscriptores

Son personas naturales que reciben certificados FEA bajo esta politica. Se identifican por su DID en formato `did:goya:{pubkey_hex[..16]}`, derivado canonicamente via `identity::did::did_from_pubkey_hex()`.

Requisitos para ser suscriptor FEA:

- Persona natural mayor de 18 anos.
- Titular de un RUT chileno valido.
- Haber completado el proceso de verificacion de identidad presencial o por videoconferencia.
- Haber aceptado las condiciones de uso del certificado.

2.4.4 Partes confiantes

Son entidades que verifican firmas electronicas avanzadas realizadas con certificados emitidos bajo esta politica. Las partes confiantes deben:

- Validar la cadena de certificacion completa hasta la CA Raiz.
- Verificar el estado de revocacion via CRL u OCSP.
- Confirmar que el OID de la politica (1.3.6.1.4.1.99999.2.1) corresponde al uso previsto.
- Verificar la vigencia temporal del certificado.

2.4.5 Otros participantes

- **TSA:** Proporciona sellos de tiempo RFC 3161 bajo OID de politica 1.3.6.1.4.1.99999.1.1.
- **Respondedor OCSP:** Estado de certificados en tiempo real segun RFC 6960.
- **Cliente TSL:** Consulta listas de confianza externas segun ETSI TS 119 612.

2.5 Marco legal y normativo

Norma	Descripcion
Ley 19.799	Sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
DS 24/2019	Norma Tecnica para Firma Electronica Avanzada
Ley 19.628	Sobre proteccion de la vida privada (datos personales)
EA-103 v2.1	Guia de Acreditacion de la Entidad Acreditadora
ETSI TS 102 042	Requisitos de politica para CAs que emiten certificados cualificados
ETSI EN 319 411-1	Requisitos de politica y seguridad para TSP – Requisitos generales
ETSI EN 319 411-2	Requisitos de politica y seguridad para TSP que emiten QCerts
ETSI EN 319 412-2	Perfiles de certificado para persona natural
ETSI EN 319 412-5	QCStatements
RFC 3647	Marco de Politica de Certificados y CPS
RFC 5280	Perfil de certificado y CRL para Internet PKI
RFC 6960	OCSP
FIPS 204	ML-DSA (Module Lattice Digital Signature Algorithm)
BSI TR-02102-1 (2024)	Recomendaciones de algoritmos criptograficos y longitudes de clave (BSI, Alemania)
ANSSI Avis PQC (2024)	Recomendacion sobre migracion a criptografia post-cuantica con modo hibrido obligatorio (ANSSI, Francia)

3. Responsabilidades de Publicacion y Repositorio

3.1 Repositorio

Goya Ledger SpA mantiene un repositorio web accesible publicamente en <https://goya.cl/pki/> que contiene:

- La presente Politica de Certificados (CP) en su version vigente.
- La Declaracion de Practicas de Certificacion (CPS).
- Los certificados de la CA Raiz y CA Intermedia.
- Las CRLs vigentes.
- El punto de acceso del respondedor OCSP.
- Informacion de contacto para consultas y reclamos.

3.2 Frecuencia de publicacion

Elemento	Frecuencia
Politica de Certificados	Dentro de 24 horas de cada modificacion aprobada
CPS	Dentro de 24 horas de cada modificacion aprobada
CRLs	Cada 1 hora y dentro de 60 minutos de cada revocacion
Certificados CA	Dentro de 24 horas de emision o renovacion

3.3 Control de acceso al repositorio

- El repositorio es de solo lectura para el publico.
- La publicacion requiere autorizacion del Oficial de Seguridad.
- Los cambios se registran en el log de auditoria con marca de tiempo y DID del operador.
- La integridad del repositorio se verifica mediante hash SHA-256 almacenado en blockchain.

4. Identificacion y Autenticacion

4.1 Registro inicial

4.1.1 Tipos de nombre

Los certificados FEA emitidos bajo esta politica contienen:

- **Subject DN:** Nombre legal completo del suscriptor.
- **serialNumber (OID 2.5.4.5):** RUT del suscriptor en formato XX.XXX.XXX-D.

- **DID:** `did:goya:{pubkey_hex[..16]}` en extension `SubjectAlternativeName`.
- **Country (C):** CL.
- **Organization (O):** Nombre de la organizacion (si aplica).

4.1.2 Significado de los nombres

Los nombres en el certificado representan la identidad legal verificada del suscriptor conforme al Registro Civil e Identificación de Chile. El RUT es el identificador tributario único asignado por el Servicio de Impuestos Internos.

4.1.3 Unicidad de nombres

El par (RUT, DID) es único dentro de la PKI. No se emiten dos certificados FEA vigentes para el mismo RUT con el mismo par de claves.

4.1.4 Verificación de identidad para personas naturales

El proceso de verificación de identidad (identity proofing) para certificados FEA requiere nivel High (`AssuranceLevel::High`) y se ejecuta mediante:

1. **Comparecencia presencial** ante un oficial de RA o **videoconferencia** con verificación documental en tiempo real.
2. Presentación de cédula de identidad chilena vigente o pasaporte.
3. Validación del RUT mediante algoritmo módulo 11 implementado en `validate_rut()`.
4. Verificación biométrica (captura facial comparada contra documento).
5. Verificación de número telefónico y correo electrónico.
6. Firma del contrato de suscriptor (SF01).

La RA registra cada decisión con el DID del oficial, marca de tiempo y disposición (aprobado/rechazado/pendiente).

4.1.5 Verificación de identidad para personas jurídicas

No aplica bajo esta política. Los certificados de sello electrónico para personas jurídicas (`LegalPerson`) se rigen por una política separada.

4.2 Renovación de certificado (re-key)

- La renovación requiere que el certificado anterior este vigente o haya expirado hace menos de 30 días.
- Si han transcurrido más de 36 meses desde la última verificación presencial, se requiere nueva verificación de identidad completa (re-verification interval: 36 meses, conforme a `IdentityProofingPolicy`).
- La renovación genera un nuevo par de claves ML-DSA-65.
- El certificado anterior se revoca automáticamente al emitir el nuevo.

4.3 Revocacion

La autenticacion para solicitudes de revocacion se realiza mediante:

- Autenticacion con el certificado vigente del suscriptor (firma de la solicitud).
 - Comparecencia presencial con identificacion ante la RA.
 - Codigo de revocacion entregado al suscriptor durante la emision.
-

5. Requisitos Operacionales del Ciclo de Vida

5.1 Solicitud de certificado

1. El solicitante completa el formulario SF01 (Solicitud de Certificado FEA).
2. La solicitud se registra en el sistema de la RA con un identificador unico.
3. El solicitante genera su par de claves ML-DSA-65 en su dispositivo.
4. El solicitante envia el CSR (Certificate Signing Request) firmado con su clave privada.

5.2 Procesamiento de la solicitud

1. La RA verifica la identidad del solicitante segun la seccion 4.1.4.
2. La RA valida el CSR y verifica la posesion de la clave privada.
3. La RA registra la aprobacion o rechazo con DID del oficial y marca de tiempo.
4. Plazo maximo de procesamiento: 5 dias habiles desde la recepcion de documentacion completa.

5.3 Emision del certificado

1. Tras aprobacion de la RA, la CA Intermedia firma el certificado X.509v3.
2. El certificado incluye:
 - Extension certificatePolicies (OID 2.5.29.32) con OID 1.3.6.1.4.1.99999.2.1 y CPS Pointer.
 - Extension QCStatements con QcCompliance (OID 0.4.0.1862.1.1) y QcType esign (OID 0.4.0.1862.1.6.1).
 - Key Usage: digitalSignature, nonRepudiation.
 - Subject con RUT en serialNumber (OID 2.5.4.5).
3. Vigencia: 365 dias (conforme a certificate_lifetime_days: 365).
4. El certificado se registra en la base de datos de la CA y se publica en el repositorio.
5. Se genera un sello de tiempo TSA (OID 1.3.6.1.4.1.99999.1.1) para la transaccion de emision.

5.4 Aceptacion del certificado

1. El suscriptor recibe notificacion de emision.
2. El suscriptor verifica el contenido del certificado (nombre, RUT, vigencia).
3. El suscriptor acepta formalmente el certificado dentro de 7 dias habiles.
4. La falta de aceptacion en plazo implica revocacion automatica.

5.5 Uso del certificado

Los certificados FEA emitidos bajo esta politica se utilizan exclusivamente para:

- Firma electronica avanzada de documentos (Ley 19.799, Art. 3 letra b).
- Firma de contratos electronicos con equivalencia a firma manuscrita.
- Firma de declaraciones juradas y documentos legales electronicos.
- Autenticacion de identidad en sistemas que requieran FEA.

Usos prohibidos:

- Cifrado de datos o comunicaciones.
- Firma de codigo ejecutable.
- Emision de certificados subordinados.
- Cualquier uso incompatible con las extensiones Key Usage del certificado.

5.6 Suspension

La suspension temporal de un certificado procede cuando:

- El suscriptor sospecha compromiso de clave pero no lo ha confirmado.
- Se requiere investigacion sobre uso indebido del certificado.
- Orden judicial que ordene la suspension temporal.

Condiciones de la suspension:

- Duracion maxima: 30 dias.
- El certificado aparece en la CRL con codigo de razon `certificateHold`.
- Transcurridos 30 dias sin resolucion, la suspension se convierte en revocacion definitiva.
- El suscriptor puede solicitar la reactivacion dentro del plazo si demuestra que no hubo compromiso.

5.7 Revocacion

La revocacion definitiva de un certificado procede cuando:

- El suscriptor solicita la revocacion.
- Se confirma compromiso de la clave privada del suscriptor.
- Los datos del certificado son inexactos o han dejado de ser validos.
- El suscriptor incumple las obligaciones del contrato de suscriptor.
- La CA cesa operaciones.
- Orden judicial o administrativa que ordene la revocacion.
- El suscriptor fallece.
- Se detecta uso del certificado para fines no autorizados.

Procedimiento de revocacion:

1. Recepcion de la solicitud de revocacion (suscriptor, RA, orden judicial).
2. Autenticacion del solicitante segun seccion 4.3.
3. Registro de la revocacion con DID del operador y marca de tiempo.
4. Publicacion en CRL dentro de 60 minutos.
5. Actualizacion del respondedor OCSP.

6. Notificacion al suscriptor.

5.8 Expiracion y archivo

- Los certificados expirados se archivan por un periodo minimo de 7 anos (conforme a `log_retention_years: 7`).
 - Los registros de identidad del suscriptor se retienen por 7 anos (conforme a `document_retention_years: 7`).
 - Transcurrido el periodo de retencion, los datos personales se destruyen conforme a la Ley 19.628.
-

6. Controles de Seguridad Fisica, Procedimental y de Personal

6.1 Controles de seguridad fisica

Las instalaciones donde opera la CA cumplen con:

- Perimetro de seguridad fisica con control de acceso biometrico.
- Sala de servidores con acceso restringido a personal autorizado.
- Videovigilancia 24/7 con retencion de grabaciones por 90 dias.
- Deteccion y supresion de incendios.
- Suministro electrico redundante (UPS + generador).
- Control ambiental (temperatura 18-24 C, humedad 40-60%).

Los detalles de implementacion se encuentran en PS03 (Continuidad del Negocio) y la documentacion de seguridad fisica del PSC.

6.2 Controles procedimentales

- Segregacion de funciones: ningun individuo realiza simultaneamente funciones de CA y RA.
- Doble control para operaciones criticas: generacion de claves CA, emision de CRL manual, restauracion de respaldos.
- Procedimientos documentados para cada operacion del ciclo de vida del certificado.
- Revision de procedimientos al menos una vez al ano.

6.3 Controles de personal

- Verificacion de antecedentes para todo el personal con acceso a sistemas CA/RA.
- Capacitacion inicial y anual en seguridad de la informacion, proteccion de datos y procedimientos PKI.
- Acuerdos de confidencialidad firmados por todo el personal.
- Revocacion inmediata de accesos al terminar la relacion laboral.

Estos controles estan detallados en PS04 (Plan SGSI) y PS02 (Politica de Seguridad de la Informacion).

7. Controles Tecnicos de Seguridad

7.1 Generacion y proteccion de claves

7.1.1 Claves de la CA

- Generacion mediante ceremonia de claves documentada, con presencia de auditor externo.
- Algoritmo: ML-DSA-65 (FIPS 204), nivel de seguridad NIST 3 (143-bit quantum security).
- Almacenamiento en HSM certificado FIPS 140-3 Level 3 (via PKCS#11).
- Respaldo de claves CA en HSM secundario en sitio alternativo.
- Los procedimientos de gestion de claves CA estan detallados en PS06.

7.1.2 Claves del suscriptor

- Generacion en el dispositivo del suscriptor mediante CSPRNG (OsRng).
- Algoritmo: ML-DSA-65 (FIPS 204).
- Almacenamiento seguro: clave privada protegida con ZeroizeOnDrop y mlock.
- La clave privada nunca abandona el dispositivo del suscriptor.
- La CA nunca tiene acceso a la clave privada del suscriptor.

7.1.3 Algoritmos soportados

Algoritmo	Estandar	Uso	OID QcType
ML-DSA-65	FIPS 204	FEA (persona natural)	0.4.0.1862.1.6.1
Ed25519	FIPS 186-5	FES (firma simple)	N/A

7.2 Registros de auditoria

- Log append-only con evidencia de integridad mediante cadena de hashes.
- Retencion: 7 anos.
- Revision: anual conforme a la Guia de la Entidad Acreditadora.
- Eventos registrados: emision, revocacion, suspension, acceso a claves CA, acceso fisico, cambios de configuracion.

Los controles de auditoria estan definidos en AuditPolicy con tamper_evidence y review_frequency en src/pki_policy.rs.

7.3 Sellado de tiempo

Toda operacion critica del ciclo de vida del certificado se sella con la TSA interna bajo OID 1.3.6.1.4.1.99999.1.1, conforme a RFC 3161 y con precision NTP verificada.

7.4 Proteccion de red

- Comunicaciones CA-RA sobre TLS mutuo.
- Segmentacion de red: la CA opera en un segmento aislado sin acceso directo desde Internet.
- El respondedor OCSP y el repositorio CRL son los unicos componentes expuestos al exterior.
- Deteccion de intrusiones y monitoreo continuo.

8. Perfiles de Certificado, CRL y OCSP

8.1 Perfil de certificado FEA (persona natural)

Campo	Valor
Version	v3 (X.509v3)
Serial Number	Entero positivo unico generado por CSPRNG
Signature Algorithm	ML-DSA-65 (FIPS 204)
Issuer	CN=Goya Ledger Intermediate CA, O=Goya Ledger SpA, C=CL
Validity	365 dias
Subject CN	Nombre legal completo del suscriptor
Subject serialNumber	RUT (OID 2.5.4.5)
Subject C	CL

Extensiones:

Extension	OID	Valor	Critica
Key Usage	2.5.29.15	digitalSignature, nonRepudiation	Si
Extended Key Usage	2.5.29.37	id-kp-emailProtection	No
Certificate Policies	2.5.29.32	OID 1.3.6.1.4.1.99999.2.1, CPS Pointer https://goya.cl/pki/cps	No
Subject Alternative Name	2.5.29.17	DID did:goya:{pubkey_hex[. .16]}	No
	2.5.29.35		No

Extension	OID	Valor	Crítica
Authority Key Identifier		Hash de clave publica CA Intermedia	
Subject Key Identifier	2.5.29.14	Hash de clave publica del suscriptor	No
CRL Distribution Points	2.5.29.31	https://goya.cl/pki/crl	No
Authority Info Access	1.3.6.1.5.5.7.1.1	OCSP: https://goya.cl/pki/ocsp	No
QC Compliance	0.4.0.1862.1.1	Presente	No
QC Type	0.4.0.1862.1.6	esign (0.4.0.1862.1.6.1)	No

Este perfil corresponde a CertProfileType::NaturalPerson con AssuranceLevel::High en src/pki_policy.rs.

8.2 Perfil de CRL

Campo	Valor
Version	v2
Signature Algorithm	ML-DSA-65
Issuer	CN=Goya Ledger Intermediate CA
This Update	Hora de emision (UTC)
Next Update	This Update + 1 hora
Formato	RFC 5280

Cada entrada revocada incluye:

- Numero de serie del certificado.
- Fecha de revocacion.
- Codigo de razon (keyCompromise, affiliationChanged, superseded, cessationOfOperation, certificateHold).

8.3 Perfil OCSP

Campo	Valor
Protocolo	RFC 6960
URL	https://goya.cl/pki/ocsp
Firma	Certificado OCSP Responder firmado por CA Intermedia
Algoritmo de firma	ML-DSA-65
Tiempo de respuesta	Menos de 3 segundos
Validez de respuesta	1 hora

9. Administracion de la Politica

9.1 Organizacion responsable

Goya Ledger SpA es responsable de la administracion de esta politica a traves de su Comite de Politica de Certificados, compuesto por:

- Gerente General (presidente del comite).
- Oficial de Seguridad de la Informacion.
- Arquitecto Criptografico.
- Asesor Juridico.

9.2 Datos de contacto

Contacto	Valor
Organizacion	Goya Ledger SpA
Email de politica	pki-policy@goya.cl
URL	https://goya.cl/pki/

9.3 Procedimiento de cambio de politica

1. Propuesta de cambio presentada por cualquier miembro del comite o por la Entidad Acreditadora.
2. Evaluacion de impacto por el Oficial de Seguridad y el Asesor Juridico.
3. Aprobacion por el Comite de Politica (mayoria simple, con voto dirimente del Gerente General).
4. Periodo de notificacion publica de 30 dias antes de la entrada en vigencia, salvo cambios de emergencia.
5. Publicacion de la nueva version en el repositorio con actualizacion del historial de versiones.
6. Notificacion a suscriptores vigentes y a la Entidad Acreditadora.

9.4 Procedimiento de aprobacion del CPS

El CPS debe ser consistente con esta politica. Cualquier cambio al CPS que modifique las garantias, obligaciones o niveles de aseguramiento definidos en esta politica requiere aprobacion previa del Comite de Politica.

10. Obligaciones y Responsabilidades

10.1 Obligaciones de la CA

1. Emitir certificados exclusivamente tras verificacion exitosa de identidad por la RA.
2. Publicar CRLs dentro de 1 hora de cada revocacion.

3. Mantener registros de auditoria por 7 anos (append-only, con evidencia de integridad).
4. Someterse a inspeccion anual conforme a la Guia de la Entidad Acreditadora.
5. Proteger las claves de la CA en HSM certificado FIPS 140-3 Level 3.
6. Operar conforme al CPS vigente y a esta politica.
7. Notificar a los suscriptores y a la Entidad Acreditadora de cualquier compromiso de claves CA dentro de 24 horas.
8. Mantener seguro de responsabilidad civil conforme al Artículo 14 de la Ley 19.799.
9. Publicar esta politica y el CPS en un repositorio accesible al publico.
10. Proporcionar servicio de revocacion disponible 24/7.

10.2 Obligaciones de la RA

1. Verificar la identidad del solicitante conforme al Artículo 15 de la Ley 19.799.
2. Validar el RUT chileno mediante algoritmo modulo 11.
3. Retener los registros de verificacion de identidad por 7 anos.
4. Reportar solicitudes de identidad sospechosas dentro de 24 horas.
5. Proteger la informacion personal del solicitante conforme a la Ley 19.628.
6. Mantener registro auditable de todas las decisiones de aprobacion y rechazo.
7. Operar bajo supervision de la CA y conforme a los procedimientos documentados.

10.3 Obligaciones del suscriptor

1. Proporcionar informacion de identidad exacta y completa a la RA.
2. Proteger la clave privada contra acceso no autorizado.
3. Utilizar el certificado exclusivamente para los fines autorizados en la seccion 5.5.
4. Reportar compromiso o sospecha de compromiso de la clave privada dentro de 24 horas.
5. Solicitar la revocacion del certificado cuando los datos ya no sean validos.
6. No compartir ni transferir la clave privada a terceros.
7. Cumplir con las condiciones del contrato de suscriptor (SF01).

10.4 Obligaciones de la parte confiante

1. Validar la cadena de certificacion completa hasta la CA Raiz antes de confiar en una firma.
 2. Verificar el estado de revocacion del certificado mediante CRL u OCSP.
 3. Verificar que el OID de la politica (1.3.6.1.4.1.99999.2.1) corresponde al uso previsto.
 4. Verificar la vigencia temporal del certificado.
 5. Asumir responsabilidad por las consecuencias de confiar en un certificado sin realizar las verificaciones anteriores.
-

11. Garantías, Seguros y Responsabilidad Civil

11.1 Garantías de la CA

Goya Ledger SpA garantiza que:

- Los certificados FEA se emiten conforme a los procedimientos establecidos en esta política y el CPS.
- La identidad del suscriptor ha sido verificada conforme al nivel High de aseguramiento.
- Los certificados contienen información exacta al momento de la emisión.
- Los mecanismos de revocación están disponibles 24/7.
- Las claves de la CA se protegen conforme a los estándares indicados en la sección 7.1.

11.2 Limitaciones de garantía

Goya Ledger SpA no garantiza:

- La exactitud de la información del certificado más allá de lo verificable por la RA.
- El uso apropiado del certificado por parte del suscriptor.
- La seguridad de la clave privada del suscriptor.
- La disponibilidad ininterrumpida de los servicios (sujeto a los SLA definidos en PS03).

11.3 Seguro de responsabilidad civil

Conforme al Artículo 14 de la Ley 19.799, Goya Ledger SpA mantiene un seguro de responsabilidad civil que cubre:

- Danos derivados de la emisión de certificados con información inexacta imputable a la CA.
- Danos derivados de fallos en la revocación oportuna de certificados.
- El monto de la cobertura cumple con los mínimos establecidos por el DS 181/2002.

11.4 Limitación de responsabilidad

- Goya Ledger SpA no responde por daños derivados del uso del certificado para fines no autorizados.
- La responsabilidad se limita al monto de la cobertura del seguro, salvo dolo o culpa grave.
- No se responde por daños indirectos, lucro cesante o daños consecuenciales, salvo los establecidos por la Ley 19.799.

11.5 Fuerza mayor

Goya Ledger SpA no responde por incumplimientos derivados de caso fortuito o fuerza mayor, conforme al Artículo 45 del Código Civil chileno. Los procedimientos de contingencia se detallan en PS03 (Plan de Continuidad del Negocio).

12. Privacidad y Protección de Datos

12.1 Marco legal de protección de datos

El tratamiento de datos personales por parte de Goya Ledger SpA se rige por la Ley 19.628 sobre Protección de la Vida Privada y, en lo aplicable, por el Reglamento General de Protección de Datos de la UE (GDPR) para operaciones con alcance europeo.

12.2 Datos personales recopilados

En el contexto de la emisión de certificados FEA, se recopilan los siguientes datos personales:

Dato	Finalidad	Base legal
Nombre completo	Inclusión en certificado, verificación de identidad	Ley 19.799 Art. 15
RUT	Inclusión en certificado (OID 2.5.4.5), verificación tributaria	Ley 19.799 Art. 15
Cedula de identidad / Pasaporte	Verificación de identidad presencial	Ley 19.799 Art. 15
Datos biométricos (facial)	Verificación de identidad	Consentimiento explícito
Correo electrónico	Notificaciones del ciclo de vida del certificado	Contrato de suscriptor
Teléfono	Verificación de segundo factor	Contrato de suscriptor
DID	Identificación en la PKI	Contrato de suscriptor

12.3 Principios de tratamiento

- **Finalidad:** Los datos se utilizan exclusivamente para la emisión, gestión y revocación de certificados.
- **Proporcionalidad:** Solo se recopilan los datos estrictamente necesarios.
- **Exactitud:** El suscriptor tiene derecho a solicitar la corrección de datos inexactos.
- **Seguridad:** Los datos se almacenan con controles de acceso y cifrado en reposo.

- **Temporalidad:** Los datos se retienen por el periodo legalmente exigido (7 años) y se destruyen al vencimiento.

12.4 Derechos del titular

Conforme a la Ley 19.628, el suscriptor tiene derecho a:

- Acceso: Conocer los datos personales almacenados por la CA.
- Rectificación: Solicitar la corrección de datos inexactos.
- Cancelación: Solicitar la eliminación de datos cuando ya no sean necesarios (sujeto al periodo de retención legal).
- Oposición: Oponerse al tratamiento de datos para fines no relacionados con la certificación.

Las solicitudes se dirigen a privacidad@goya.cl y se resuelven dentro de 15 días hábiles.

12.5 Transferencia internacional de datos

Los datos personales de suscriptores se almacenan en territorio chileno. La transferencia internacional solo procede:

- Con consentimiento explícito del titular.
- Cuando el país destinatario ofrezca garantías adecuadas de protección.
- Cuando sea requerido por tratado internacional o cooperación judicial.

12.6 Datos publicados en el certificado

El suscriptor consiente expresamente, mediante la firma del contrato de suscriptor (SF01), que los siguientes datos se incluyan en el certificado y sean accesibles públicamente:

- Nombre completo.
- RUT.
- DID.
- Clave pública.

12.7 Incidentes de seguridad de datos

En caso de brecha de seguridad que afecte datos personales:

1. Notificación al titular dentro de 72 horas.
 2. Notificación a la Entidad Acreditadora dentro de 24 horas.
 3. Registro del incidente conforme a PS07 (Plan de Gestión de Incidentes).
 4. Evaluación de impacto y medidas correctivas.
-

13. Referencias

Referencia	Titulo
Ley 19.799	Sobre documentos electronicos, firma electronica y servicios de certificacion (Chile, 2002)
DS 181/2002	Reglamento de la Ley 19.799
DS 24/2019	Norma Tecnica para la Firma Electronica Avanzada
Ley 19.628	Sobre proteccion de la vida privada (Chile, 1999)
EA-103 v2.1	Guia de Acreditacion de PSC – Entidad Acreditadora
ETSI TS 102 042	Policy requirements for certification authorities issuing qualified certificates
ETSI EN 319 411-1	Policy and security requirements for TSPs issuing certificates – General
ETSI EN 319 411-2	Policy and security requirements for TSPs issuing QCerts
ETSI EN 319 412-2	Certificate profiles – Part 2: Natural persons
ETSI EN 319 412-5	QCStatements
RFC 3647	Internet X.509 PKI Certificate Policy and CPS Framework
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol – OCSP
RFC 3161	Internet X.509 PKI Time-Stamp Protocol (TSP)
FIPS 204	Module-Lattice-Based Digital Signature Standard (ML-DSA)
FIPS 186-5	Digital Signature Standard (DSS)
FIPS 140-3	Security Requirements for Cryptographic Modules
BSI TR-02102-1 (2024)	Kryptographische Verfahren: Empfehlungen und Schlüssellängen
ANSSI Avis PQC (2024)	Avis relatif a la migration vers la cryptographie post-quantique